

Monitoring EHPAD : architecture et écarts

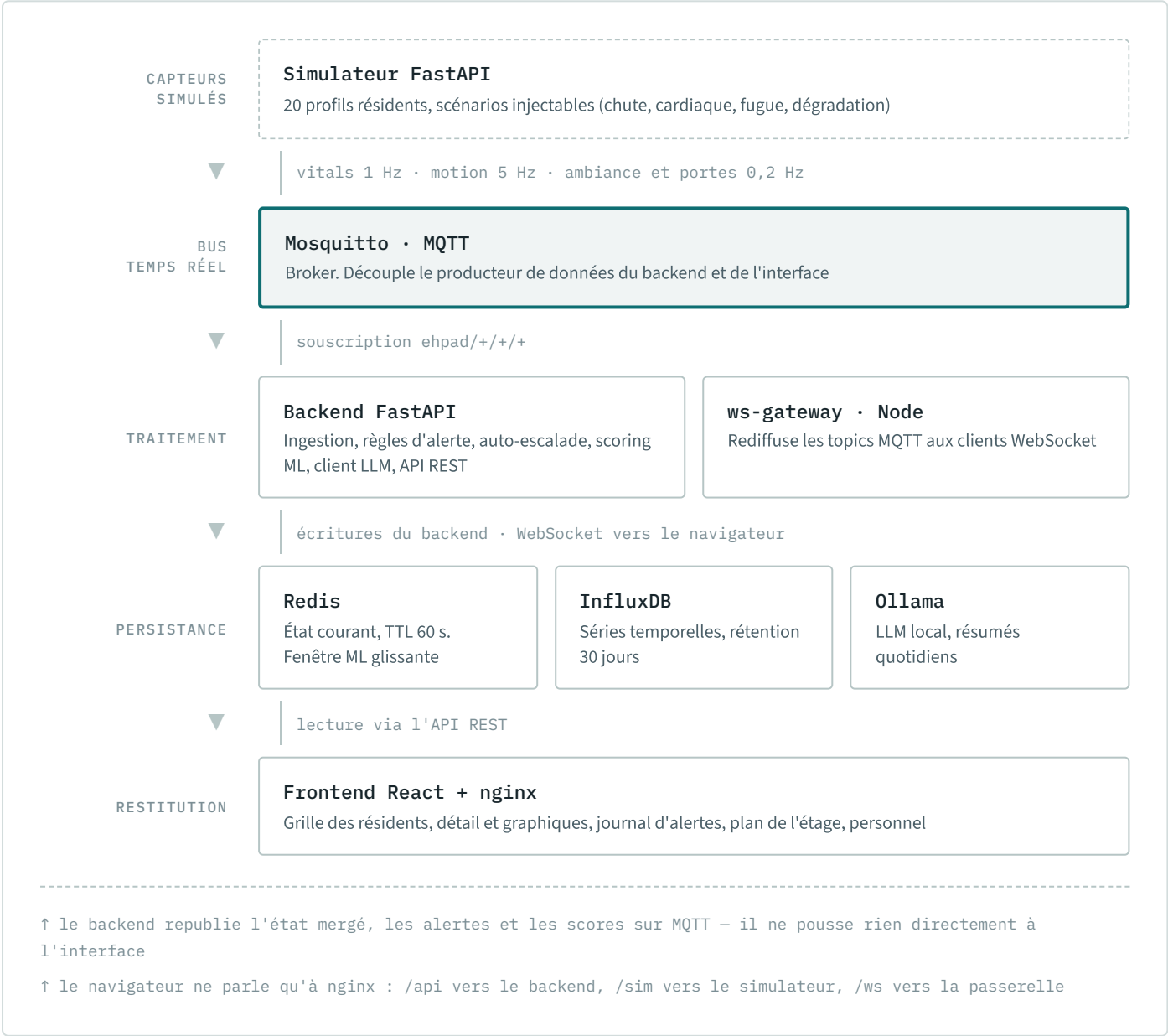
Surveillance temps réel de 20 résidents : capteurs simulés, ingestion MQTT, scoring ML, alertes à cinq niveaux avec auto-escalade, détection de fugue, résumé quotidien par LLM local. Voici l'architecture telle qu'elle est, puis ce qui manque pour en faire un produit utilisable dans un établissement.

9 services Docker · ~4 700 lignes · 59 tests backend, 0 côté front ·
74 commits, avril 2026

Code du projet analysé : github.com/Usannazcedric/projet-2-iot-sante

01

Architecture



MQTT fait la colonne vertébrale : le simulateur se remplace par de vrais capteurs sans toucher au backend. Une seule origine côté navigateur, d'où l'absence de configuration CORS dans le code. Les neuf services démarrent par un unique `docker compose up`.

02

Écarts techniques

Chaque ligne porte la dimension de la grille qu'elle couvre.

	ÉCART	CRITICITÉ	EFFORT
T1 DONNÉES & CAPTEUR	Aucun capteur réel Toute la mesure est tirée d'une loi normale par le simulateur. Pas de pilote BLE ou LoRa, pas d'appairage, pas de gestion de batterie ni de perte de lien, et aucun traitement des artefacts de mesure — bracelet retiré, brassard mal posé, résident qui bouge.	BLOQUANT	Élevé
T2 DIFFUSION	L'alerte ne sort pas du navigateur Un toast dans l'onglet ouvert, rien d'autre. La nuit, personne devant l'écran : il faut du SMS, du push ou le bip de l'établissement.	BLOQUANT	Moyen
T3 IDENTITÉ	Aucune authentification Toutes les routes sont ouvertes. N'importe qui lit les constantes des 20 résidents et peut acquitter — donc éteindre — une alerte vitale.	BLOQUANT	Moyen
T4 SÉCURITÉ DEVICE	MQTT anonyme, secrets en clair, pas de mise à jour <code>allow_anonymous true</code> et zéro TLS : un faux client peut injecter de fausses constantes. Le jeton InfluxDB est écrit en clair dans <code>docker-compose.yml</code> , et aucun mécanisme de mise à jour à distance (OTA) n'est prévu pour un parc de capteurs.	BLOQUANT	Moyen
T5 RÉFÉRENTIELS	Résidents et personnel codés en dur Déclarés en Python. Admettre un résident ou le changer de chambre demande un redéploiement.	BLOQUANT	Moyen
T6 IA	Modèle entraîné sur nos propres données simulées L'IsolationForest apprend le simulateur, pas la physiologie. Aucun jeu de données réel, aucune mesure de faux positifs.	MAJEUR	Élevé
T7 DISPONIBILITÉ	Un seul backend, escalades en mémoire S'il redémarre, les escalades en cours disparaissent sans bruit : une alerte non acquittée ne montera jamais. La panne est silencieuse, c'est le pire des cas.	MAJEUR	Élevé

	ÉCART	CRITICITÉ	EFFORT
T8 DONNÉES	Données éphémères, aucune sauvegarde Volumes Docker locaux, rétention Influx de 30 jours. Aucune trace horodatée de qui a acquitté quelle alerte — rien d'opposable en cas de litige.	MAJEUR	Moyen
T9 INTEROPÉRABILITÉ	Aucun lien avec le système d'information de l'établissement Ni FHIR, ni HL7, aucune route d'export. Les données restent prisonnières de la plateforme et ne remontent pas au dossier de soin : le soignant ressaisit à la main.	MAJEUR	Moyen
T10 QUALITÉ	Pas de CI, aucun test front 59 tests backend solides, mais rien sur React ni sur la chaîne complète capteur → alerte → écran, et rien ne s'exécute automatiquement.	MINEUR	Faible

03

Écarts produit et réglementaires

Ceux qu'aucun sprint de développement ne ferme : ils se traitent en amont du code.

	ÉCART	CRITICITÉ	EFFORT
R1 STATUT	Le produit n'est jamais qualifié Bien-être ou dispositif médical ? Il calcule un score de risque et déclenche une alerte de soin : très probablement un DM au sens du règlement 2017/745, donc marquage CE, dossier technique et organisme notifié. La question n'a pas été instruite.	BLOQUANT	Hors dev
R2 RISQUES	Aucune analyse de risques « Que se passe-t-il si l'alerte ne part pas ? » n'a pas de réponse écrite, alors que c'est exactement le mode de défaillance qui blesse. Ni AMDEC, ni ISO 14971, ni conduite à tenir en cas de panne.	BLOQUANT	Moyen
R3 DONNÉES PERSONNELLES	Ni hébergement HDS, ni AIPD, ni consentement Des données de santé nominatives imposent les trois. Aucun n'existe : le système tourne sur des volumes Docker locaux, sans analyse d'impact ni recueil du consentement des résidents ou de leurs tuteurs.	BLOQUANT	Hors dev
R4 VALIDATION	Performance jamais prouvée contre une référence Ni sensibilité, ni spécificité, ni taux de fausses alertes par nuit. Impossible d'affirmer que le système détecte mieux qu'une ronde — or c'est la seule promesse qui justifie de l'acheter.	MAJEUR	Élevé

ÉCART		CRITICITÉ	EFFORT
R5 USAGE	Jamais testé avec de vrais soignants ni résidents Zéro essai terrain. On ignore si cinq niveaux d'alerte restent tenables une nuit à deux aides-soignantes, et si le tableau de bord est lisible dans le couloir plutôt qu'au bureau.	MAJEUR	Moyen
R6 MODÈLE ÉCONOMIQUE	Qui paie n'a pas été abordé L'établissement, l'ARS, la famille ? La réponse décide du périmètre à construire : un forfait par lit et un abonnement par résident ne donnent pas le même produit.	MINEUR	Hors dev

Bloquant = empêche la mise en service Majeur = exploitation dégradée Mineur = dette acceptable
Faible ≤ 2 j · Moyen 3-8 j · Élevé > 8 j · Hors dev = ni code ni sprint

04

Ce qu'il faut en retenir

La chaîne fonctionne de bout en bout : un capteur publie, l'alerte arrive à l'écran en moins de deux secondes, l'escalade s'enclenche seule, le ML anticipe une dégradation. Comme démonstrateur, c'est complet.

Ce qui manque n'est presque jamais une fonctionnalité. Ce sont les capteurs physiques, une identité derrière chaque geste, et une alerte qui franchit les limites du navigateur. Tant que ces trois-là manquent, un établissement ne peut pas brancher le système.

Et la moitié du chemin restant ne s'écrit pas en code. Qualifier le produit, analyser les risques, encadrer les données personnelles, mesurer la détection contre une référence, essayer le tout avec de vrais soignants : six écarts sur seize se jouent avant le premier commit. C'est là que se trouve la vraie distance avec un produit fini.

- D'abord** — T2, T3 et R2 : faire sortir l'alerte de l'écran, savoir qui l'acquitte, et écrire noir sur blanc ce qui se passe quand elle ne part pas.
- Ensuite** — T4, T5, T8 et R3 : chiffrement, référentiels en base, sauvegardes, et le cadre RGPD-HDS sans lequel aucune donnée réelle ne peut entrer.
- Enfin** — T1, T6, R1 et R4 : vrais capteurs, validation du modèle contre une référence, qualification réglementaire. Les gros chantiers, et ils vont ensemble.